

Kubernetes Risky Permission Assignment



Intro

Now that you are more familiar with the concept of RBAC and risky permissions – it'll be best to feel it with your hands 😊

Don't forget: Notes are blue, Exercise is orange, Commands are Green

Prerequisites:

!!! Make sure your machine have 2 cpus or more (AWS -> t2.medium)

Install minikube

```
curl -LO https://storage.googleapis.com/minikube/releases/latest/minikube-linux-amd64
```

```
sudo install minikube-linux-amd64 /usr/local/bin/minikube
```

Install Docker (driver for minikube)

```
curl -fsSL https://get.docker.com -o get-docker.sh
```

```
sudo sh get-docker.sh
```

```
minikube start
```

Check if minikube works

```
Kubectl get pods --all-namespaces
```

If kubectl not installed

Unset

```
curl -LO "https://dl.k8s.io/release/$(curl -L -s  
https://dl.k8s.io/release/stable.txt)/bin/linux/amd64/kubectl"
```

```
sudo install -o root -g root -m 0755 kubectl /usr/local/bin/kubectl
```

#install KubiScan

git clone <https://github.com/cyberark/KubiScan.git>

cd KubiScan

```
apt-get update
apt-get install -y python3 python3-pip
pip3 install -r requirements.txt
```

```
# Change the path in red (on ubuntu ec2 it'll probably be ~/KubiScan)
alias kubiscan='python3 /<KubiScan_folder>/KubiScan.py'
```

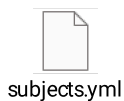
The assignment:

In this assignment you'll run an open-source tool called KubiScan –

<https://github.com/cyberark/KubiScan>

This tool, made by Eviatar Gerzi, is a great tool that will help you to assess the risky permission within your k8s cluster.

For it to have more “meat”, let's start with applying this configuration on your cluster (you need to upload it to your server)–



subjects.yml



role-binding.yml



risky-roles.yml



nitzanim-namespace.
yml



pods-with-sa.yml

```
kubectl apply -f nitzanim-namespace.yml
kubectl apply -f risky-roles.yml
kubectl apply -f subjects.yml
kubectl apply -f role-binding.yml
kubectl apply -f pods-with-sa.yml
```

Install KubiScan and run –

```
kubiscan -h
```

Now you have all you need to know about this tool 😊

1. List all the risky subjects in the cluster
 - a. kubiscan -rs
2. List all the risky pods (“hot pod”) in the cluster
 - a. kubiscan -rp
3. Get the Roles associated with the subject “sa-any-resource-impersonate”
 - a. kubiscan -aars "sa-any-resource-impersonate" -ns "nitzanim" -k "serviceaccount"

Bonus – You can hear more from Eviatar about RBAC, risky permission and KubiScan here –

https://www.youtube.com/watch?v=1LMoOCftVC4&ab_channel=RSAConference

Good Luck!